



Risk Management and Assessment – Term Project
Fundamentals of Information Assurance
CS6411

November 21, 2024

Mackenzie Chase 

Arthkumar Patel 

Introduction

The Chronicle is an independent university-based publication, which operates within the Tantramar University. They report news regarding the events of the University and the surrounding area. Due to it being a source of reliable information for a lot of people, The Chronicle operates in a challenging cybersecurity environment and faces evolving threats. There have been incidents such as a former employee gaining unauthorized access to the system. This has encouraged the publication to implement more stringent and robust cybersecurity practices.

This risk management report aims to provide a comprehensive assessment of potential risks that may compromise the assets, reputation, and operations of the publication. By leveraging the established frameworks such as NIST Risk Management Framework, this assessment will identify the key threats, vulnerabilities, and their impacts to the Chronicle followed by mitigation strategies to reduce the likelihood and severity of such risks.

The Scope of this assessment includes the journal's physical and digital assets. It excludes detailed financial data and external cloud technologies. Using a combination of qualitative measurements and industry best practices, this report offers insights to enhance the security posture.

The Goal of this report is to improve the publication's operations while minimizing the effects of disruptions. Moreover, it provides solutions to prevent, detect, and mitigate potential risks in order to maintaining trust and credibility among its stakeholders.

The Chronicle

Information Security Mission Statement

The Chronicle journal is committed to protecting its critical assets, such as its website, journalistic integrity, and financial data, with low to very low tolerance for risks in these areas. However, due to budgetary and operational constraints, the journal accepts medium tolerance for risks related to social media reputation, physical asset security, and personal device usage, provided these do not pose significant or frequent threats to the organization's mission and credibility.

Assumptions	Constraints
Existence of Internal and External Threats	Budgetary constraints for IT resources
Heavy reliance on hardware and software tools	Dependence on university IT infrastructure.
Staff lack training and awareness of cyber threats	Some IT infrastructure is restricted by the university

Risk Tolerance:

Due to The Chronicle being a news agency, its reputation is the most important aspect to protect. The news journal has a **low tolerance for risks** that compromise the integrity of its content, the confidentiality of unpublished articles, and the availability of its publishing systems, as these directly impact its credibility and operations. Incidents, such as temporary service disruptions or hardware failures, are moderately tolerable.

Methodology:

In this assessment we utilized a **Qualitative approach**. Due to the size and nature of the Chronicle's operations, there is little financial gain for the publication. It prioritizes trust among its stakeholders which is difficult to quantify. Furthermore, we used **Asset / Impact based Analysis** which looks at asset-specific risk levels based on likelihood of threats affecting each asset. Finally, we consider the impact on Confidentiality, Integrity, and Availability (C.I.A.) for the publication if an asset is compromised.

Cybersecurity Incident at The Chronicle:

Incident Type: Unauthorized accesses by an Insider

The Chronicle recently experienced an incident where a former employee had exploited their retained credentials to gain unauthorized access to sensitive systems, including client databases and financial records. The breach occurred due to a failure to immediately revoke access upon termination and inadequate monitoring of unusual login activity.

Risk Assessment Procedure:

Standard Utilized – NIST SP 800-30 - Guide for Conducting Risk Assessments

Tool Utilized – MITRE ATT&CK Framework.

Asset Identification and Classification:

The asset classification was done as per the NIST SP 800-30, where we have a scale for the assets and the classification of assets hence ranking the assets based on their severity and their importance as per C.I.A.

Asset Classification Scale

Since The Chronicle is a publication the most important and high risk will be to the integrity of the content and that is most likely to be attacked, however with that we also have the operations and financial aspect which are a potential target. Since there are not a lot of financial aspects related to the organization, we will decide based on the consequences on their credibility and operations.

Scale	Reasoning
High	Assets crucial for the day-to-day operations and integrity of The Chronicle and no compromises will be accepted.
Medium	Assets that are in control of Chronicle, but their CIA is not crucial to the day-to-day operations of the Chronicle
Low	Assets that are required for operations but pose no threat to the Integrity of the organization

Based on this Assessment the assets are classified based on their value to the organization:

High: A002, A003, A004, A006, A007, A008, A009, A010, A013, A014

Medium: A001, A005, A011, A012

Risk Identification:

Asset Classification as per their C.I.A:

Asset	Confidentiality	Integrity	Availability	Overall	Reasoning
Data and Information Assets					
Public Articles Archive (A001)	Medium	High	Medium	Medium	Important for maintaining historical accuracy but less sensitive than unpublished content.
Database (Unpublished Articles) (A002)	High	High	High	High	Contains sensitive, unpublished information critical to the publication's reputation and trust.
Financial Data (A003)	High	High	High	High	Includes payment records, employee salaries, and budget information; highly sensitive and critical.
Employee Credentials (A004)	High	High	High	High	Unauthorized access could lead to system compromise or leaks of sensitive data.
Internal Policies and Procedures (A005)	Medium	Medium	Low	Medium	Modification or knowledge of those procedures could lead to information about attack surfaces.
Software Assets					
WordPress Platform - CMS (A006)	High	High	High	High	Critical for Creating and publishing the articles
Flywheel Hosting (A007)	High	High	High	High	A breach could result in no availability.
Social Media Accounts (A008)	High	High	Medium	High	a compromise could damage trust
Email System (A009)	High	High	High	High	a breach could result in phishing attacks or sensitive data exposure.
Access Management Solutions (A010)	High	High	High	High	breach could lead to abuse of credentials
Hardware Assets					
Office Desktops (6 iMacs) (A011)	Medium	Medium	Medium	Medium	Used for daily operations; compromise.
Office RFID Access Systems (A012)	Medium	Medium	Medium	Medium	Important to prevent unauthorized access to equipment/data.
Backup Devices (HDD, SSD, etc.) (A013)	High	High	High	High	compromise could lead to data loss or incomplete recovery.
Network devices (Routers) (A0014)	Medium	High	High	High	downtime could halt all activities.

Threat, Vulnerability and Asset Analysis:

Based on the assets, a threat source and threat event list were created following that we identified the vulnerabilities utilizing the MITRE framework as well as the NIST SP 800-30, we were able to review the severity of the vulnerability and assess the risk for the asset.

Risk ID	Threat ID	Threat Source	Threat Event	Vulnerability	Affected Asset(s)	Risk
R001	T001	Hacktivists	Website defacement to spread misinformation.	Lack of Multi-Factor Authentication (MFA)	A001 (Public Articles Archive)	Reputation damage due to misinformation on the website.
R002	T002	Disgruntled Insider	Unauthorized deletion or alteration of articles.	Excessive Access Privileges	A001 (Public Articles Archive), A002 (Database)	Loss of trust and operational disruption due to altered or deleted critical content.
R003	T003	Phishing Campaigns	Credential theft via phishing emails.	Lack of MFA, Ineffective Awareness Training	A004 (Employee Credentials)	Compromise of employee accounts leading to further exploitation of sensitive systems.
R004	T004	Cybercriminals	Data exfiltration for financial gain.	Misconfigured Database Permissions	A002 (Database), A004 (Employee Credentials)	Financial losses and exposure of sensitive data due to unauthorized access.
R005	T005	Script Kiddies	Brute force attacks on CMS login credentials.	Lack of MFA	A001 (Public Articles Archive)	Unauthorized access to CMS; potential for limited data compromise or disruption.
R006	T006	Natural Disasters	Flooding damaging physical assets.	Weak Physical Security	A013 (Backup Devices), A003 (Financial Data)	Data loss and financial recovery challenges due to physical asset damage.
R007	T007	Hardware Failures	Backup device failure during recovery.	Limited Backup Testing	A013 (Backup Devices)	Inability to recover critical data after a system failure.
R008	T008	System Misconfiguration	Misconfigured CMS exposing sensitive data.	Misconfigured Database Permissions	A001 (Public Articles Archive), A002 (Database)	Unauthorized access to sensitive data due to poor configurations, leading to loss of trust and data breaches.
R009	T009	Software Bugs	CMS plugin errors disrupting publishing.	Software Bugs in CMS Plugins	A001 (Public Articles Archive)	Publishing process interruptions, reducing operational efficiency and credibility.

R010	T010	Third-Party Service Failures	Hosting outages or DNS disruptions.	Dependence on Third-Party Services	A007 (Flywheel Hosting)	Website unavailability, affecting trust and operational continuity.
R011	T011	Human Error	Accidental publication of sensitive data.	Lack of Logging and Monitoring	A002 (Database), A005 (Internal Policies)	Exposure of sensitive or inaccurate data, leading to operational and reputational damage.
R012	T012	Power Outages	Temporary unavailability of office systems.	Single Point of Failure in IT Resources	A011(Office Desktops)	Temporary loss of productivity and access to critical systems.
R013	T013	Insider Threats	Unauthorized use of retained access by an ex-Employee	Gain Privileged Access	A001 (Public Articles Archive), A002 (Database)	Misuse of access to compromise data integrity and confidentiality.
R014	T014	Cyberattacks	Disruption of publication systems.	Outdated CMS Software	A001 (Public Articles Archive)	Loss of availability and operational disruption due to system compromise.
R015	T015	Hardware Failure	Device failure causing data loss.	Limited Backup Testing	A013(Backup Devices), A011(Office Systems)	Data loss and operational inefficiencies due to hardware malfunctions.
R016	T016	Human Error	Publication of sensitive or incorrect data.	Lack of Logging and Monitoring	A002 (Database), A005 (Internal Policies)	Operational inefficiencies and loss of trust due to inadvertent publication of incorrect or sensitive content.

In this phase, we classified assets based on their importance to the organization's confidentiality, integrity, and availability (C.I.A). Critical assets such as unpublished article databases, employee credentials, financial data, and content management systems (CMS) were identified as high-priority due to their role in maintaining operations and trust. Threats, vulnerabilities, and potential risks were assessed using frameworks like MITRE ATT&CK and NIST SP 800-30. Key risks include phishing attacks, insider threats, data breaches, and CMS misconfigurations, each mapped to specific assets and vulnerabilities. This analysis highlights the need for appropriate security measures to protect these assets and maintain organizational resilience.

Risk Analysis (Risk Register)

Risk ID	Threat Source	Threat Event	Vulnerability	Affected Asset(s)	Potential Impact	Likelihood	Impact	Risk Level	MITRE ATT&CK TTP
R001	Hacktivists	Website defacement to spread misinformation.	Lack of Multi-Factor Authentication (MFA)	A001 (Public Articles Archive)	Damage to reputation and trust.	Moderate	High	Moderate	T1190: Exploit Public-Facing Application
R002, R013	Disgruntled Insider	Unauthorized deletion or alteration of articles.	Excessive Access Privileges	A002 (Database)	Loss of trust and operational disruption.	Moderate	High	Moderate	T1078: Valid Accounts
R003	Phishing Campaigns	Credential theft via phishing emails.	Lack of MFA, Ineffective Awareness Training	A004 (Employee Credentials)	Compromise of sensitive employee credentials.	High	High	High	T1566: Phishing
R004	Cybercriminals	Data exfiltration for financial gain.	Misconfigured Database Permissions	A002 (Database), A004 (Employee Credentials)	Financial losses and data breaches.	High	High	High	T1020: Data Transfer to Cloud
R005	Script Kiddies	Brute force attacks on CMS login credentials.	Lack of MFA	A001 (Public Articles Archive)	Limited compromise of content.	Low	Low	Low	T1110: Brute Force
R006	Natural Disasters	Flooding damaging physical assets.	Weak Physical Security	Backup Devices, A003 (Financial Data)	Loss of critical assets and financial data.	Low	High	Moderate	T1580: Physical Destruction

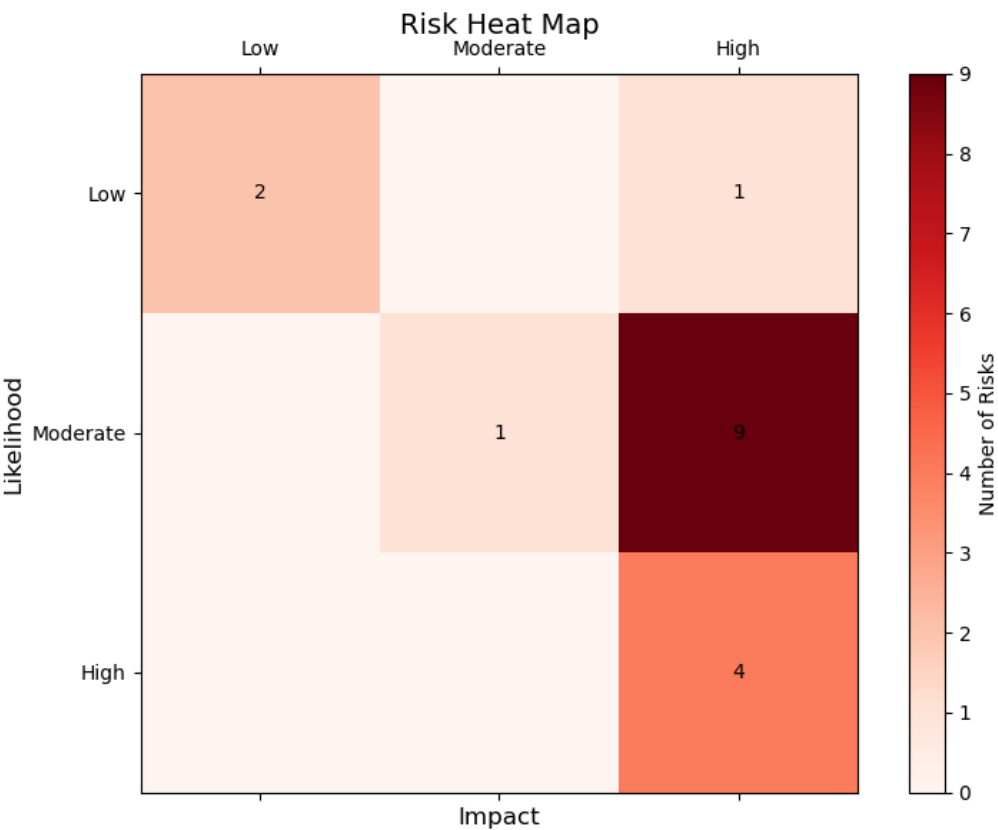
R007, R015	Hardware Failures	Backup device failure during recovery.	Limited Backup Testing	Backup Devices	Inability to recover critical data.	Moderate	High	Moderate	T1529: System Shutdown/Reboot
R008	System Misconfiguration	Misconfigured CMS exposing sensitive data.	Misconfigured Database Permissions	A001 (Public Articles Archive), A002 (Database)	Loss of sensitive data and availability.	High	High	High	T1068: Exploitation for Privilege Escalation
R009	Software Bugs	CMS plugin errors disrupting publishing.	Software Bugs in CMS Plugins	A001 (Public Articles Archive)	Disruption to publishing operations.	Moderate	Moderate	Moderate	T1203: Exploitation for Client Execution
R010	Third-Party Failures	Hosting outages or DNS disruptions.	Dependence on Third-Party Services	Flywheel Hosting, DNS	Website inaccessibility, affecting operations.	Moderate	High	Moderate	T1499: Endpoint Denial of Service
R011, R016	Human Error	Accidental publication of sensitive data.	Lack of Logging and Monitoring	A002 (Database), A005 (Internal Policies)	Exposure of sensitive or inaccurate data.	Moderate	High	Moderate	T1074: Data Staged
R012	Power Outages	Temporary unavailability of office systems.	Single Point of Failure in IT Resources	Office Desktops	Temporary loss of productivity.	Low	Low	Low	T1499: Endpoint Denial of Service
R014	Cyberattacks	Disruption of publication systems.	Outdated CMS Software	A001 (Public Articles Archive)	Loss of availability and operational disruption.	High	High	High	T1195: Supply Chain Compromise

Risk Level Matrix:

Risk Level	Risk IDs	Priority
High Risk	R003, R004, R008, R014	Immediate attention required.
Moderate Risk	R001, R002, R006, R007, R009, R010, R011, R013, R015, R016	Address after critical issues.
Low Risk	R005, R012	Monitor and reassess periodically.

The **High Priority Risks** (R003, R004, R008, R014) demand immediate mitigation due to their potential to cause severe disruptions to operations, data integrity, and reputation. **Moderate Priority Risks** should be addressed promptly to avoid operational inefficiencies and reputational harm, while **Low Priority Risks** can be managed with routine security measures

Heat Map for Risk Register:



Risk Evaluation

1. High Priority Risks

Characteristics:

- These risks have either **High Likelihood**, **High Impact**, or both.
- They represent immediate and significant threats to the organization's operations, reputation, and financial standing.

Risk ID	Description	Justification
R003	Credential theft via phishing campaigns.	High likelihood and impact due to phishing prevalence, lack of MFA, and insufficient training.
R004	Data exfiltration for financial gain.	High risk due to misconfigured databases and potential for sensitive data loss.
R008	Misconfigured CMS exposing sensitive data.	High likelihood of privilege escalation, impacting both availability and confidentiality.
R014	Cyberattacks disrupting publication systems.	High likelihood of exploitation due to outdated CMS software, impacting critical operations.

To improve security of the publication it is necessary to implement mitigations for these risks first or it can lead to major disruptions, data breaches, legal penalties, and loss of trust from stakeholders, requiring immediate attention.

2. Moderate Priority Risks

Characteristics:

- Moderate likelihood or impact.
- Addressing these risks reduces the probability of operational disruption or data loss.

Risk ID	Description	Justification
R009	CMS plugin errors disrupting publishing.	Software bugs occur periodically but have limited impact, affecting publishing rather than sensitive data.
R001	Website defacement impacting reputation and trust.	Moderately likely due to hacktivist motivations, but safeguards like web application firewalls mitigate impact.
R002, R013	Unauthorized alteration of articles by insiders.	Insider threats pose moderate risk due to operational access, mitigated by access controls.
R007, R0015	Backup device failure affecting recovery.	Moderate likelihood, but potential loss of critical data elevates its priority.
R010	Third-party outages or DNS disruptions.	Hosting dependency poses operational risk, but redundancy mitigates immediate impact.
R011, R016	Accidental publication of sensitive data.	Moderate likelihood, but poor monitoring exacerbates potential reputational and legal risks.
R014	Device failure causing operational data loss.	Hardware issues occur periodically but can be mitigated by robust backup testing and redundancy.

These risks result in localized disruptions or delays, such as interruptions to publishing workflows.

While less severe, they can still harm productivity and credibility if not addressed promptly.

3. Low Priority Risks

Characteristics:

- Low likelihood or impact.
- These risks cause minor inconveniences with minimal long-term impact. They are typically manageable with routine processes.

Risk ID	Explanation
R005	Brute force attacks on CMS login credentials have low likelihood due to the low sophistication of script kiddies and the availability of basic mitigation strategies (e.g., MFA).
R012	Power outages have a low likelihood of occurring frequently, and their impact is temporary, making them a low-priority risk.

The risk evaluation categorizes threats into high, moderate, and low priorities based on their likelihood and impact. **High-priority risks** (e.g., phishing, data exfiltration, system misconfigurations, and cyberattacks) require immediate mitigation as they pose significant threats to operations, reputation, and finances. **Moderate-priority risks** (e.g., natural disasters, hardware failures, and software bugs) demand planned responses to prevent disruptions or data loss. **Low-priority risks** (e.g., brute force attacks and power outages) are manageable with routine security measures and pose minimal long-term impact. Addressing high-priority risks first is critical to conserving the organization's integrity and trust.

Risk Mitigation Strategies:

Threat Source	Risk ID	MITRE Mitigation Strategy and Preventative Measures	MITRE Detection Strategy
Hacktivists & Script Kiddies	R001, R005	Apply multi-factor authentication (M1032), secure configurations (M1054) Implement Web Application Firewall	Monitor web server logs for anomalous behavior (DS0009)
Disgruntled Insider	R002, R013	Limit access privileges (M1028), enforce account management policies (M1018)	Monitor access patterns for unusual activities (DS0017)
Phishing Campaigns	R003	conduct awareness training (M1017)	Analyze email content and user behavior for phishing signs (DS0029)
Cybercriminals	R004	Implement strong database access controls (M1021), encrypt data at rest (M1040)	Detect unusual data transfer activity (DS0002)
Natural Disasters	R006	Develop disaster recovery plans (M1057), implement physical security measures (M1053)	Monitor for environmental alerts and asset status (DS0036)
Hardware Failures	R007, R015	Regularly test and validate backups (M1053), use redundant systems (M1037).	Audit backup integrity and failure logs (DS0018)
System Misconfiguration	R008	Secure configuration management (M1038), harden CMS configurations (M1054).	Detect unusual privilege escalation attempts (DS0028).
Software Bugs	R009	Regularly patch and update plugins (M1051), conduct software testing (M1048)	Monitor plugin logs and crash reports (DS0014)
Third-Party Failures	R010	Use redundant service providers (M1037), ensure SLAs with hosting providers (M1056)	Monitor Flywheel availability metrics (DS0023)
Human Error	R011, R016	Implement data classification and monitoring (M1036), use access controls (M1021)	Detect unusual data access patterns or modifications (DS0002)
Power Outages	R012	Deploy UPS systems (M1053), ensure alternate IT resources are available (M1057)	Monitor system uptime and power anomalies (DS0034)
Cyberattacks	R014	Regularly update CMS software (M1051), conduct supply chain risk assessments (M1055)	Monitor software supply chain changes and CMS behavior (DS0009)
Hardware Failure	R015	Conduct regular hardware maintenance (M1033), test backups regularly (M1053)	Track hardware diagnostics and error logs (DS0018)

In summary, The Chronicle would benefit to employ strong passwords with Multifactor Authentication (MFA) for all its current and future employees. The use of detection systems for anomalous activity for systems as well as employee actions would be an asset. We recommend keeping company devices and personal devices used for company purposes up to date with the latest software patches. Once an employee has left the Chronicle, it is imperative their access rights are revoked or reduced to appropriate levels. A disaster recovery plan, in addition to, frequent backups would help the paper mitigate losses if such an event occurs.

Response Plan & Monitoring

We recommend the Chronicle implement the following:

- Establish a Response Team with clearly defined roles.
- Implement MFA for all the users.
- Revoke access promptly after employee termination.
- Training staff on phishing and security awareness.
- Development of a disaster recovery plan with good offsite backups.
- Budget permitting, integrate a SIEM tool to monitor or analyze unauthorized logins to help in early detection of potential threats.
- Patching of vulnerabilities in the CMS and its plugins.
- Resolve any database misconfigurations
- Strengthen the access control mechanism.

We recommend the immediate implementation of MFA with a phased plan in which within the first three months the access audits are reviewed. In the following three months after that, implement the monitoring tools and perform CMS hardening, and implement and test the disaster recovery capabilities.

We further recommend any new staff are given the appropriate training on phishing and online security. While these mitigation strategies will reduce the chances of threats, there are still residual risks that may affect the Chronicle.

We assert this risk assessment is valid for 12 months, with a strong recommendation to review the results of the mitigation strategies after the 6 months transition period.

Organizational Risks

Risk ID	Risk Description	Threat Source	Vulnerability	Affected Asset(s)	Likelihood	Impact	Risk Level	Proposed Mitigation
RISK-L001	Legal action due to defamatory content in articles.	Legal Claims	Insufficient editorial oversight.	Published Content	Moderate	High (Integrity)	High	Establish an editorial review board to fact-check and approve articles, especially sensitive topics.
RISK-L002	Copyright infringement due to improper use of media assets.	Legal Claims	Improper sourcing of copyrighted material.	Published Articles, Media Assets	Moderate	Moderate (Integrity)	Moderate	Use licensed media or ensure proper attribution for images, videos, and other content.

Chronicle faces two organizational risks: potential legal action after publication of defamatory content (RISK-L001), and copyright infringement from improper use of media assets (RISK-L002). To mitigate these, Chronicle should establish a robust editorial review team, source their media content appropriately with acknowledgement, and ensure compliance with any national or local laws where necessary. Regular training for staff on legal and regulatory standards will minimize legal and reputational harm.

Summary

In this assessment, we evaluated the cybersecurity risks faced by The Chronicle. While operating with very limited resources and a reliance on CMS and university IT infrastructure, their priority is data confidentiality and integrity while maintaining a low tolerance for risks to its reputation. Utilizing the NIST Risk Management Framework and MITRE ATT&CK database of known attack techniques, key threats such as phishing attacks, insider misuse, and system misconfigurations were identified. Assets were classified based on their C.I.A requirements, along with a heat map highlighting high-risk areas like data breaches and system vulnerabilities.

We have also included the organizational risks that can also cause significant harm to the organization and along with them we have also provided possible mitigation strategies.

To mitigate these risks, our report emphasizes preventative measures like Multi-Factor Authentication (MFA), secure configurations, and disaster recovery plans. Detection mechanisms such as log monitoring and anomaly detection were also recommended, along with a phased response plan addressing high-priority risk first. Regular software updates, employee training, and access revocation are key strategies to enhance security.

By implementing these measures, The Chronicle can ensure operational continuity and safeguard its reputation. Continuous monitoring, annual risk assessments, and proactive mitigation efforts will help the organization address evolving threats and maintain trust among its stakeholders.

And the suggested response plan is establishing a response Team, implement MFA, conduct access audits, and train staff on phishing awareness as immediate priorities. Follow up with CMS hardening, monitoring tools, and disaster recovery testing to enhance security and resilience within six months.